



TECNICATURA SUPERIOR EN
Telecomunicaciones

Seguridad IoT

Estrategia y Gestión de Proyectos para Soluciones IoT

Clase 07

Tema: Introducción al Pentesting en Sistemas IoT. Herramientas de análisis de tráfico y detección de vulnerabilidades.

Tutor : Mario Gonzalez

ÍNDICE

1. Objetivos
2. Introducción al Pentesting
3. Conceptos éticos y legales
4. ¿Por qué realizar Pentesting en IoT?
5. Metodología de un Pentest IoT
6. Fase de reconocimiento
7. Fase de análisis de red
8. Kali Linux
9. Wireshark
10. Captura y análisis de tráfico
11. Interpretación de paquetes
12. Identificación de vulnerabilidades
13. Casos reales
14. Buenas prácticas
15. Actividad práctica
16. Resumen de la clase

Referencias bibliográficas

1. Objetivos de la clase

El objetivo de esta clase es introducir a los estudiantes en el concepto de Pentesting aplicado a sistemas IoT, comprendiendo cómo se detectan vulnerabilidades antes de que puedan ser explotadas por atacantes reales.

Se analizarán herramientas ampliamente utilizadas en el ámbito profesional como Kali Linux y Wireshark, aprendiendo a capturar, observar e interpretar tráfico de red para identificar problemas de seguridad en dispositivos conectados.

Al finalizar la clase el alumno será capaz de:

- Comprender qué es un Pentest.
- Diferenciar auditoría de seguridad y ataque real.
- Utilizar Wireshark para analizar tráfico.
- Comprender el uso de Kali Linux.
- Detectar información sensible transmitida en la red.
- Relacionar vulnerabilidades observadas con riesgos reales en sistemas IoT.

2. Introducción al Pentesting

Pentesting es la abreviatura de Penetration Testing o prueba de penetración.

Consiste en simular ataques controlados sobre un sistema con el objetivo de identificar vulnerabilidades antes de que sean explotadas por atacantes reales.

La idea principal no es destruir ni comprometer un sistema, sino evaluar su nivel de seguridad.

Un Pentest permite responder preguntas como:

- ¿Puede alguien acceder a mi dispositivo?
- ¿Las credenciales viajan protegidas?
- ¿El sistema expone información sensible?
- ¿Existen configuraciones inseguras?

En IoT esto es especialmente importante porque muchos dispositivos permanecen conectados a Internet las 24 horas.

3. Conceptos éticos y legales

Las pruebas de penetración deben realizarse únicamente sobre sistemas autorizados.

Existen tres enfoques principales:

White Box

El auditor conoce completamente el sistema.

Dispone de:

- Código fuente
- Diagramas
- Credenciales
- Arquitectura

Es el método más utilizado en auditorías internas.

Gray Box

El auditor posee información parcial.

Representa un escenario intermedio.

Black Box

El auditor no conoce ningún detalle previo.

Simula el comportamiento de un atacante externo.

Importante

Realizar pruebas sobre sistemas ajenos sin autorización puede constituir un delito informático.

Toda práctica académica deberá realizarse únicamente sobre:

- Equipos propios
- Laboratorios
- Máquinas virtuales
- Entornos controlados

4. ¿Por qué realizar Pentesting en IoT?

Los dispositivos IoT suelen presentar características particulares:

- Recursos limitados
- Sistemas operativos simplificados
- Actualizaciones poco frecuentes
- Configuraciones inseguras por defecto

Además, muchos dispositivos permanecen años en funcionamiento sin mantenimiento.

Esto aumenta considerablemente la superficie de ataque.

Ejemplos comunes:

- Cámaras IP
- Alarmas conectadas
- Sensores industriales
- PLCs
- Gateways MQTT
- Routers domésticos

5. Metodología de un Pentest IoT

Un Pentest profesional suele dividirse en varias etapas.

A. Reconocimiento

Obtención de información.

Se busca identificar:

- Direcciones IP
- Servicios activos
- Puertos abiertos
- Sistemas operativos

B. Enumeración

Obtención de información más detallada.

Por ejemplo:

- Versiones de software
- Usuarios existentes
- Servicios vulnerables

C. Análisis

Se buscan vulnerabilidades conocidas.

D. Explotación

Se verifica si la vulnerabilidad realmente puede aprovecharse.

E. Reporte

Se documentan hallazgos y recomendaciones.

6. Fase de reconocimiento

El reconocimiento suele ser la etapa más importante.

Muchas veces un atacante puede obtener gran cantidad de información sin interactuar directamente con el dispositivo.

Ejemplos:

- Direcciones IP visibles
- Dominios públicos
- Certificados digitales
- Versiones de servidores

Información obtenida:

- Topología de red
- Dispositivos conectados
- Servicios publicados

7. Fase de análisis de red

Una gran cantidad de vulnerabilidades puede detectarse simplemente observando el tráfico.

Al analizar paquetes pueden encontrarse:

- Usuarios
- Contraseñas
- Tokens
- APIs
- Direcciones IP
- Información de sensores

Herramientas utilizadas:

- Wireshark
- tcpdump
- Tshark

8. Kali Linux

Kali Linux es una distribución Linux especializada en ciberseguridad. Es mantenida por la organización Offensive Security.

Incluye cientos de herramientas orientadas a:

- Análisis de redes
- Forense digital
- Pentesting
- Criptografía
- Ingeniería inversa

Actualmente es uno de los sistemas operativos más utilizados por profesionales de seguridad.

Herramientas populares incluidas

- Wireshark
- Nmap
- Burp Suite
- Metasploit
- Aircrack-ng
- Hydra
- John the Ripper

Para esta materia nos enfocaremos principalmente en:

- Wireshark
- Nmap

9. Wireshark

Wireshark es un analizador de protocolos de red.

Permite capturar paquetes en tiempo real y observar exactamente qué información circula por la red.

Puede utilizarse para:

- Diagnóstico
- Resolución de problemas
- Auditorías
- Seguridad

Es una de las herramientas más utilizadas del mundo.

¿Qué puede mostrar Wireshark?

Dependiendo del protocolo:

- Direcciones IP
- Direcciones MAC
- DNS
- HTTP
- MQTT
- TLS
- Modbus
- CoAP

Si el protocolo no utiliza cifrado, también puede mostrar:

- Usuarios
- Contraseñas
- Payloads completos

10. Captura y análisis de tráfico

Una captura consiste en registrar todos los paquetes que circulan por una interfaz de red.

Ejemplo:

ESP32 → Broker MQTT

Durante la captura pueden observarse:

CONNECT

CONNACK

PUBLISH

SUBSCRIBE

DISCONNECT

Cuando MQTT no utiliza TLS, toda esta información puede visualizarse fácilmente.

Filtros útiles

Mostrar tráfico MQTT:

mqtt

Mostrar puerto MQTT:

tcp.port == 1883

Mostrar tráfico TLS:

tls

Mostrar HTTPS:

tcp.port == 443

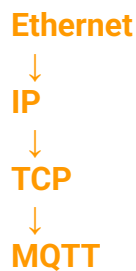
Mostrar MQTTS:


```
tcp.port == 8883
```

11. Interpretación de paquetes

Cada paquete contiene múltiples capas.

Ejemplo:



Cada capa aporta información diferente.

Ethernet:

- MAC origen
- MAC destino

IP:

- IP origen
- IP destino

TCP:

- Puertos

MQTT:

- Topic
- Payload
- Credenciales

12. Identificación de vulnerabilidades

Durante un análisis pueden detectarse problemas como:

Credenciales expuestas

usuario=admin

password=1234

Protocolos inseguros

HTTP

MQTT

Telnet

FTP

Falta de autenticación

Acceso libre a servicios.

Información sensible

- Tokens
- Datos personales
- Configuraciones internas

Indicadores de riesgo

Alta criticidad:

- Contraseñas visibles
- Acceso remoto sin autenticación
- MQTT abierto a Internet

Media criticidad:

- Versiones antiguas
- Certificados vencidos

Baja criticidad:

- Información de banners
- Servicios innecesarios

13. Casos Reales de Vulnerabilidades y Ataques en Sistemas IoT

La historia reciente de Internet demuestra que muchos de los mayores incidentes de seguridad tuvieron como origen dispositivos IoT mal configurados, credenciales débiles o servicios expuestos a Internet.

Analizar casos reales permite comprender cómo pequeñas fallas de configuración pueden transformarse en incidentes de gran escala con consecuencias económicas, operativas y sociales.

Caso 1: Cámaras IP con Credenciales por Defecto

Durante más de una década numerosos fabricantes comercializaron cámaras IP con configuraciones predeterminadas extremadamente inseguras.

Miles de dispositivos eran distribuidos utilizando credenciales estándar como:

Usuario: admin
Contraseña: admin

o

Usuario: admin
Contraseña: 1234

Muchos usuarios instalaban las cámaras y nunca modificaban estas credenciales.

A partir de 2010 diversos investigadores comenzaron a descubrir que era posible localizar cámaras conectadas directamente a Internet utilizando motores de búsqueda especializados como Shodan.

En muchos casos se podía acceder remotamente a:

- Video en tiempo real.
- Configuración de la cámara.
- Grabaciones almacenadas.
- Control de movimiento PTZ (Pan-Tilt-Zoom).
- Configuración de red.

Algunas investigaciones encontraron cámaras instaladas en:

- Hogares.
- Comercios.
- Hospitales.
- Escuelas.
- Dependencias gubernamentales.

Este problema continúa existiendo actualmente y constituye uno de los ejemplos más comunes de vulnerabilidad por configuración insegura.

Lecciones aprendidas

- Nunca utilizar credenciales por defecto.
- Deshabilitar acceso remoto innecesario.
- Mantener firmware actualizado.
- Utilizar autenticación robusta.

Material de consulta

Shodan – Search Engine for Internet Connected Devices

<https://www.shodan.io>

Artículo de referencia:

<https://www.cisa.gov/news-events/cybersecurity-advisories>

Caso 2: Brokers MQTT Expuestos en Internet

MQTT es uno de los protocolos más utilizados en sistemas IoT debido a su simplicidad y bajo consumo de recursos.

Sin embargo, numerosos estudios realizados entre 2017 y la actualidad encontraron miles de brokers MQTT accesibles públicamente desde Internet sin ningún mecanismo de seguridad.

Los investigadores detectaron servidores que permitían:

- Conexión anónima.
- Lectura de mensajes.
- Publicación de datos.
- Suscripción a topics.

Todo ello sin requerir usuario ni contraseña.

En algunos casos también se observó:

- Ausencia de TLS.
- Comunicación completamente en texto plano.
- Información sensible expuesta.

Entre los sistemas encontrados se identificaron:

- Sensores industriales.
- Sistemas de automatización.
- Alarmas domiciliarias.
- Equipos médicos.
- Cámaras IP.
- Sistemas agrícolas.
- Monitoreo de temperatura industrial.

Los datos transmitidos incluían:

- Coordenadas GPS.
- Temperaturas.
- Estados de alarmas.
- Datos médicos.
- Información de producción industrial.

Estos hallazgos demostraron que muchos sistemas IoT eran desplegados sin considerar requisitos mínimos de seguridad.

Lecciones aprendidas

- Nunca exponer MQTT directamente a Internet.
- Utilizar autenticación.
- Implementar TLS.
- Aplicar listas de control de acceso (ACL).

Material de consulta

MQTT Security Fundamentals

[HiveMQ MQTT Security Fundamentals](#)

Documentación oficial de seguridad MQTT

[EMQX Security Guide](#)

Caso 3: La Botnet Mirai

Uno de los incidentes más importantes de la historia de IoT ocurrió en 2016 con la aparición de la botnet Mirai.

Mirai fue un malware diseñado específicamente para comprometer dispositivos IoT conectados a Internet.

Su funcionamiento era relativamente simple:

1. Escanear Internet buscando dispositivos vulnerables.
2. Intentar acceder utilizando credenciales por defecto.
3. Infectar el dispositivo.
4. Incorporarlo a una red de bots controlada remotamente.

Los dispositivos más afectados fueron:

- Cámaras IP.
- DVRs.
- Routers domésticos.
- Equipos de videovigilancia.

Una vez comprometidos, los equipos pasaban a formar parte de una gigantesca red distribuida utilizada para lanzar ataques DDoS (Denial of Service).

En octubre de 2016 Mirai fue utilizada contra la empresa Dyn, proveedor de servicios DNS.

Como consecuencia, numerosos servicios de Internet dejaron de funcionar temporalmente, incluyendo:

- X (Twitter)
- Netflix

- Reddit
- Spotify
- GitHub

El ataque alcanzó volúmenes superiores a 1 Tbps, convirtiéndose en uno de los mayores ataques DDoS registrados hasta ese momento.

El caso Mirai demostró que dispositivos aparentemente simples podían transformarse en una amenaza global cuando eran desplegados sin medidas de seguridad adecuadas.

Lecciones aprendidas

- Cambiar credenciales predeterminadas.
- Actualizar firmware regularmente.
- Restringir servicios expuestos.
- Segmentar dispositivos IoT de la red principal.

Material de consulta

Análisis oficial de Mirai por Akamai

[Akamai Mirai Analysis](#)

Artículo histórico sobre el ataque a Dyn

[Dyn Cyber Attack Overview](#)

Reflexión Final

Los tres casos analizados muestran un patrón común: la mayoría de los incidentes no fueron consecuencia de técnicas avanzadas de hacking, sino de errores básicos de configuración y administración.

Contraseñas débiles, servicios expuestos innecesariamente y ausencia de mecanismos de autenticación continúan siendo algunas de las principales causas de compromisos en sistemas IoT modernos.

Comprender estos casos permite diseñar sistemas más seguros y adoptar una visión preventiva de la ciberseguridad, principio fundamental en cualquier proyecto de Internet de las Cosas.

14. Buenas prácticas

- Cambiar credenciales por defecto.
- Utilizar TLS.
- Actualizar firmware.
- Deshabilitar servicios innecesarios.
- Monitorear tráfico de red.

- Realizar auditorías periódicas.
- Utilizar autenticación fuerte.
- Implementar segmentación de red.

15. Actividad Práctica

Introducción a Kali Linux y Reconocimiento de Red

En esta actividad los estudiantes realizarán sus primeras tareas de reconocimiento y análisis de seguridad utilizando Kali Linux.

El objetivo no será explotar vulnerabilidades ni comprometer dispositivos, sino aprender a identificar equipos conectados, descubrir servicios de red y evaluar posibles superficies de ataque en un entorno controlado.

Se utilizarán herramientas profesionales ampliamente empleadas en auditorías de seguridad y análisis de redes.

Objetivos

Al finalizar la actividad el estudiante deberá ser capaz de:

- Instalar Kali Linux en una máquina virtual.
- Comprender el concepto de reconocimiento de red.
- Identificar dispositivos conectados a una red local.
- Detectar puertos abiertos.
- Reconocer servicios activos.
- Analizar riesgos básicos de exposición de servicios.
- Elaborar un informe técnico de hallazgos.

Requisitos

Cada alumno deberá disponer de:

- VirtualBox instalado.
- Imagen oficial de Kali Linux.
- Acceso a una red local.
- Un equipo con Windows, Linux o macOS.
- Broker MQTT desarrollado en actividades anteriores.
- ESP32 o dispositivo IoT utilizado en las prácticas previas.

Ejercicio 1 – Instalación de Kali Linux

Cada alumno deberá:

1. Descargar la máquina virtual oficial de Kali Linux.
2. Importarla en VirtualBox.

3. Configurar la interfaz de red en modo Bridge.
4. Verificar la conectividad con Internet.
5. Actualizar el sistema utilizando:

```
sudo apt update  
sudo apt upgrade
```

Evidencias requeridas

- Captura de VirtualBox.
- Captura del escritorio de Kali Linux.
- Captura de actualización completada.

Ejercicio 2 – Descubrimiento de Dispositivos

Utilizando Nmap, identificar todos los dispositivos activos de la red local.

Ejemplo:

```
nmap -sn 192.168.0.0/24
```

Cada alumno deberá identificar:

- Router
- PC principal
- ESP32
- Raspberry Pi (si posee)
- Broker MQTT
- Impresoras
- Cámaras IP
- Otros dispositivos encontrados

Evidencias requeridas

- Captura del comando ejecutado.
- Tabla con dispositivos encontrados.

Ejercicio 3 – Análisis de Puertos

Seleccionar al menos tres dispositivos detectados y realizar un análisis de puertos.

Ejemplo:

```
nmap -sV 192.168.0.15
```

Registrar:

- Puertos abiertos.
- Servicios detectados.
- Versiones identificadas.

Evidencias requeridas

Tabla de resultados.

Dispositivo	Puerto	Servicio
ESP32	80	HTTP
Raspberry Pi	22	SSH
Broker MQTT	1883	MQTT

Ejercicio 4 – Análisis del Broker MQTT

Realizar un escaneo específico sobre el broker MQTT utilizado en las actividades anteriores.

Ejemplo:

```
nmap -sV IP_DEL_BROKER
```

Verificar la presencia de:

- Puerto 1883
- Puerto 8883
- Puerto 9001
- Puerto 9091

Preguntas

1. ¿Qué puertos se encuentran abiertos?
2. ¿Cuáles utilizan cifrado?
3. ¿Qué riesgos existirían si estos puertos estuvieran expuestos a Internet?

Ejercicio 5 – Investigación de Herramientas

Cada alumno deberá investigar brevemente las siguientes herramientas incluidas en Kali Linux:

- Nmap
- Wireshark
- Netcat
- Traceroute
- Dig

Para cada una deberá indicar:

- Función principal.
- Ejemplo de uso.

- Aplicación en IoT.

16. Informe Técnico y Preguntas de Análisis

Preguntas de análisis

1. ¿Qué diferencia existe entre una auditoría de seguridad y un ataque real?
2. ¿Qué información puede obtenerse únicamente mediante reconocimiento de red?
3. ¿Por qué un puerto abierto no implica necesariamente una vulnerabilidad?
4. ¿Qué riesgos presenta un broker MQTT accesible desde Internet?
5. ¿Qué información puede descubrirse utilizando Nmap?
6. ¿Por qué es importante reducir la superficie de ataque de un dispositivo IoT?
7. ¿Qué servicios encontrados en la práctica considera críticos desde el punto de vista de la seguridad?
8. ¿Qué medidas recomendaría para mejorar la seguridad de los dispositivos analizados?

Entregables

Cada alumno deberá presentar:

- Captura de VirtualBox funcionando.
- Captura de Kali Linux.
- Resultados de los escaneos realizados.
- Tabla de dispositivos detectados.
- Tabla de puertos abiertos.
- Investigación de herramientas.
- Respuestas a las preguntas de análisis.
- Conclusiones personales.

Conclusión de la práctica

El reconocimiento de red constituye la primera etapa de cualquier evaluación de seguridad. Comprender qué dispositivos existen en una red, qué servicios ofrecen y qué información exponen permite identificar riesgos potenciales antes de que puedan ser aprovechados por un atacante. Kali Linux proporciona un conjunto de herramientas profesionales que facilitan estas tareas y representan el punto de partida para el análisis de seguridad en sistemas IoT.

Referencias Bibliográficas

Offensive Security. (s.f.). *Kali Linux Documentation*. Recuperado de <https://www.kali.org/docs/>

Wireshark Foundation. (s.f.). *Wireshark User Guide*. Recuperado de <https://www.wireshark.org/docs/>

OWASP Foundation. (2024). *OWASP Internet of Things Project*. Recuperado de <https://owasp.org/www-project-internet-of-things/>

NIST. (2023). *Guide to Industrial Control Systems Security*. Recuperado de <https://www.nist.gov>

Cisco Networking Academy. (2024). *Introduction to Cybersecurity*. Recuperado de <https://www.netacad.com>

Open Web Application Security Project. (2024). *OWASP Top 10 IoT Risks*. Recuperado de <https://owasp.org>

Scarfone, K., & Mell, P. (2023). *Guide to Intrusion Detection and Prevention Systems*. National Institute of Standards and Technology.